

ΑΠΟΦΑΣΗ 7/2025

Ο Πρόεδρος της Αρχής, ως μονοπρόσωπο όργανο κατά τα άρθρα 17 παρ. 1 του ν. 4624/2019 (ΦΕΚ Α' 137), στο πλαίσιο των αρμοδιοτήτων που προβλέπονται στα άρθρα 4 παρ. 3 περ. α' και 10 παρ. 4 του Κανονισμού Λειτουργίας της Αρχής (ΦΕΚ Β' 879/25.02.2022) και των εξουσιών που προβλέπονται στο άρθρο 15 παρ. 8 του ν. 4624/2019 σε συνδυασμό με το άρθρο 58 παρ. 2 στ' του Κανονισμού (ΕΕ) 2016/679 (Γενικός Κανονισμός προστασίας Δεδομένων – εφεξής ΓΚΠΔ), εξέτασε το περιστατικό παραβίασης, που αναφέρεται κατωτέρω στο ιστορικό της παρούσας απόφασης.

Η Αρχή έλαβε υπόψη τα παρακάτω:

Υποβλήθηκε στην Αρχή η με αριθμ. πρωτ. Γ/ΕΙΣ/11373/27-10-2022 γνωστοποίηση περιστατικού παραβίασης από την εταιρία «ALPHA BANK ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ» (εφεξής «εταιρία»), στην οποία αναφέρεται ότι έλαβε χώρα περιστατικό μη εξουσιοδοτημένης πρόσβασης σε προσωπικά δεδομένα από υπάλληλο της εταιρίας (εφεξής «υπάλληλος»). Σύμφωνα με τη γνωστοποίηση το περιστατικό έγινε γνωστό μέσω αναφοράς από στελέχη της Γενικής Διεύθυνσης στην Επιτροπή Αξιολογήσεως αναφορών στις 07.10.2022 και προέκυψε ως συνέπεια της εκ παραδρομής διατήρησης του ρόλου του διαχειριστή συστήματος στον υπάλληλο, ο οποίος είχε μετατεθεί εσωτερικά σε άλλη υπηρεσία. Η εκμετάλλευση της εν λόγω παράλειψης, οδήγησε σε παραβίαση της εμπιστευτικότητας για τα δεδομένα 6.176 υπαλλήλων της τράπεζας. Η γνωστοποίηση του περιστατικού υπήρξε αργοπορημένη διότι απαιτήθηκε διερεύνηση για τον εντοπισμό της πηγής διαρροής των δεδομένων και την επιβεβαίωση της παραβίασης.

Στη συνέχεια, η εταιρία απέστειλε το με αριθμ. πρωτ. Γ/ΕΙΣ/681/27-01-2023 υπόμνημα, αναφέροντας ότι:

1. Το περιστατικό οφείλεται σε μη τήρηση των εσωτερικών διαδικασιών ασφαλείας της εταιρίας.
2. Ο υπάλληλος εξακολουθούσε να διατηρεί εκ παραδρομής, λογαριασμό με διαχειριστικά δικαιώματα (System Administrator), παρά το γεγονός ότι την 1.1.2015 έπαψε να έχει θέση διαχειριστή συστήματος και μετατέθηκε σε άλλη υπηρεσία (Διεύθυνση Κυβερνοασφάλειας).
3. Με την ως άνω διαπίστωση της μη εξουσιοδοτημένης πρόσβασης από τη Διεύθυνση Εσωτερικού Ελέγχου, διακόπηκαν αυθημερόν (7.10.2022) όλα τα δικαιώματα πρόσβασης του υπαλλήλου, σε όλα τα συστήματα της Τράπεζας και ο ίδιος τέθηκε σε υποχρεωτική άδεια.
4. Λόγω του πλήθους των μη εξουσιοδοτημένων καταγεγραμμένων κινήσεων (logs) του υπαλλήλου που εντοπίστηκαν όσο και του περιεχομένου των μηνυμάτων ηλεκτρονικού ταχυδρομείου και της διαδρομής τους που έπρεπε να διερευνηθούν και συνακόλουθα του ενδεχόμενου κινδύνου για τα δικαιώματα των υποκειμένων, αποφασίσθηκε να ζητηθεί η συνδρομή εξειδικευμένης εταιρίας για την περαιτέρω έρευνα του περιστατικού και των συνεπειών του. Επελέγη η εταιρία Alvarez & Marsal, η οποία απέστειλε στην Ελλάδα, από τη Μ. Βρετανία, εξειδικευμένο προσωπικό, το οποίο σε πλήρη συνεργασία με τη Διεύθυνση Εσωτερικού Ελέγχου της Τράπεζας και με τη χρήση ειδικού λογισμικού προχώρησε σε έρευνα.
5. Στο πλαίσιο αυτής της έρευνας εντοπίσθηκε, ηλεκτρονικό μήνυμα στο οποίο περιλαμβάνονταν τα μισθολογικά στοιχεία του συνόλου του προσωπικού της Τράπεζας (6.167 άτομα), όπως και αξιολογήσεις, στοιχεία οικογενειακής κατάστασης, στοιχεία προϋπηρεσίας και προϋποθέσεις συνταξιοδότησής τους, που ο υπάλληλος, είχε ανασύρει από το σύστημα αρχειοθέτησης του ηλεκτρονικού ταχυδρομείου (Enterprise Vault). Το Enterprise Vault εντάχθηκε στο σύστημα Διαχείρισης Ειδικών/Προνομιακών Προσβάσεων¹ (Privilege Access

¹ Το Privileged Access Management (PAM) είναι μια λύση ασφάλειας ταυτοτήτων που συμβάλλει στην προστασία των οργανισμών από απειλές στον κυβερνοχώρο μέσω παρακολούθησης, εντοπισμού και αποτροπής μη εξουσιοδοτημένης προνομιακής πρόσβασης σε κρίσιμους πόρους. Το PAM λειτουργεί μέσω ενός συνδυασμού ατόμων, διαδικασιών και τεχνολογίας και παρέχει ορατότητα σχετικά με το ποιοι χρησιμοποιούν προνομιακούς λογαριασμούς και τι κάνουν ενώ είναι συνδεδεμένοι. Ο περιορισμός του αριθμού των χρηστών που έχουν

Management – εφεξής «PAM») στο οποίο καταγράφονται οι ενέργειες των διαχειριστών που πραγματοποιούνται μέσω εξ αποστάσεως συνδέσεων (remote desktop connections) στους διακομιστές, από τον Ιανουάριο του 2022. Η εν λόγω ένταξη αφορά τους διαχειριστές της Διεύθυνσης Συστημάτων Πληροφορικής, όχι όμως και αυτούς της Διεύθυνσης Κυβερνοασφάλειας και Ασφάλειας Πληροφοριών.

6. Από το Μάρτιο 2019 έως την 7.10.2022, που διακόπηκε, κατά τα προαναφερθέντα, οποιαδήποτε δυνατότητα πρόσβασης διαπιστώθηκε ότι, με εξαίρεση το χρονικό διάστημα το μήνα Δεκέμβριο του 2021 κατά το οποίο ουδεμία πρόσβαση καταγράφηκε, ο υπάλληλος πραγματοποίησε 24.625 μη εξουσιοδοτημένες κινήσεις (logged actions), στο Enterprise Vault είτε για να δει μόνο το περιεχόμενο του ηλεκτρονικού ταχυδρομείου, είτε για να λάβει το αντίστοιχο αρχείο. Σημειώνεται σχετικά ότι, το Δεκέμβριο 2021 έγινε αλλαγή των κωδικών πρόσβασης, με αποτέλεσμα να διακοπεί η ως άνω δραστηριότητα του υπαλλήλου, μέχρι τον Φεβρουάριο 2022, οπότε προφανώς περιήλθαν και πάλι σε γνώση του, με τη συνεργασία άλλου υπαλλήλου της Τράπεζας, οι κωδικοί πρόσβασης στο σύστημα Enterprise Vault.
7. Ο υπάλληλος απέστειλε 116 μηνύματα που περιλαμβάνουν πληροφορίες που περιήλθαν στην κατοχή του μέσω μη εξουσιοδοτημένης πρόσβασής του στο σύστημα ηλεκτρονικού ταχυδρομείου, σε άλλους 8 υπαλλήλους της Τράπεζας, είτε με πρωτόβουλη αποστολή από τον ίδιο, είτε κατόπιν ηλεκτρονικού αιτήματός τους που έχει καταγραφεί. Ενδεικτικά σημειώνεται ότι ο αποδέκτης των περισσότερων μηνυμάτων έχει λάβει σαράντα τρία (43) εξ αυτών και ο αποδέκτης των λιγότερων έχει λάβει ένα (1) μήνυμα. Εξ αυτών: πενήντα τρία (53) μηνύματα περιλάμβαναν προσωπικά δεδομένα, που αφορούσαν υπαλλήλους της Τράπεζας, ένα (1) μήνυμα αφορούσε προσωπικά δεδομένα φυσικών προσώπων εκτός Τράπεζας και συγκεκριμένα περιλάμβανε τα βιογραφικά δέκα οκτώ (18) υποκειμένων που υποβλήθηκαν για την πλήρωση θέσης εργασίας στην Τράπεζα (έτος 2020), οκτώ (8) μηνύματα αφορούσαν αιτήματα κάποιων εκ των 8

πρόσβαση σε λειτουργίες διαχείρισης αυξάνει την ασφάλεια του συστήματος, ενώ πρόσθετα επίπεδα προστασίας μετριάζουν τις παραβιάσεις δεδομένων από παράγοντες απειλής. (<https://www.microsoft.com/el-gr/security/business/security-101/what-is-privileged-access-management-pam>)

λειτουργιών προς τον υπάλληλο για παροχή πληροφοριών ενώ τα υπόλοιπα πενήντα τέσσερα (54) μηνύματα δεν περιλάμβαναν προσωπικά δεδομένα καθώς αφορούσαν οργανωτικές αλλαγές της Τράπεζας (σχέδια Πράξεων, Κανονισμοί Λειτουργίας κ.α.).

8. Τα παραπάνω συμπεράσματα της έρευνας γνωστοποιήθηκαν και οι ως άνω εννέα (9) συνολικά λειτουργοί της Τράπεζας (ο υπάλληλος και οι 8 αποδέκτες) εκλήθησαν σε εξηγήσεις και στη συνέχεια συμφώνησαν να αποχωρήσουν οικειοθελώς από την Τράπεζα, αναλαμβάνοντας εγγράφως υποχρέωση πλήρους συνεργασίας με την Τράπεζα, στο πλαίσιο της οποίας ανέλαβαν, μεταξύ άλλων, να επιστρέψουν τα αρχεία με προσωπικά δεδομένα που περιήλθαν στην κατοχή τους στη διάρκεια απασχόλησής τους στην Τράπεζα, να επιστρέψουν τα τερματικά (PC), laptops, κλειδιά, κωδικούς κρυπτογραφήσεως δεδομένων, κωδικούς πρόσβασης ή άλλα μέσα πρόσβασης σε χώρους ή συστήματα της Τράπεζας, που χρησιμοποιούσαν στη διάρκεια της απασχόλησής τους κτλ. Κυρίως όμως, αποχώρησαν από την Τράπεζα, αφού ανέλαβαν εγγράφως υποχρέωση πλήρους εχεμύθειας για το περιστατικό, για τον έλεγχο τήρησης της οποίας αποδέχθηκαν τη σταδιακή σε βάθος δωδεκαμήνου καταβολή σε αυτούς της νόμιμης αποζημίωσης αποχώρησης.

Περαιτέρω, η εταιρία υπέβαλε τη με αριθμ. πρωτ. Γ/ΕΙΣ/2545/05-04-2023 πλήρη γνωστοποίηση του περιστατικού παραβίασης, αναφέροντας επιπλέον ότι η μη εξουσιοδοτημένη πρόσβαση αφορά δεδομένα υγείας, ήτοι ποσοστό αναπηρίας στο πλαίσιο διαχείρισης της εργασιακής σχέσης, και οριστικοποιώντας τον αριθμό των προσώπων και αρχείων που επηρεάστηκαν από το περιστατικό. Τέλος, η εταιρία υπέβαλε το με αριθμ. πρωτ. Γ/ΕΙΣ/2546/05-04-2023 συμπληρωματικό υπόμνημα, παραθέτοντας τον ακόλουθο συγκεντρωτικό πίνακα με τα προσωπικά δεδομένα των υπαλλήλων της Τράπεζας στα οποία υπήρξε μη εξουσιοδοτημένη πρόσβαση ανά κατηγορία:

Πλήθος μηνυμάτων		Προσωπικά Δεδομένα	Πλήθος φυσικών προσώπων
Έως 14.12.2022	Μετά την 14.12.2022		
41	6	Δεδομένα μισθοδοσίας προσωπικού, έκτακτες παροχές (bonus), ηλικία, προϋπηρεσία, αξιολογήσεις, εκπαίδευση, κανάλι πρόσληψης, δεδομένα υγείας- ποσοστό αναπηρίας, οικογενειακή κατάσταση, ηλικία/ημερομηνία γεννήσεως, στοιχεία εθελουσίας εξόδου προσωπικού (VSS) (στοιχεία έτους 2019/20/21/22)	έως 6167
5	3	Στοιχεία εθελουσίας εξόδου προσωπικού (VSS) (έτους 2020, 2021)	έως 229
4	3	Αξιολογήσεις προσωπικού, των ετών 2020, 2021 και 2022	έως 138
1	-	Μισθοί Διευθυντών Διευθύνσεων (στοιχεία 2019)	86
1	-	Διευθυντές και Υποδιευθυντές Διευθύνσεων με σχόλια για την εθελουσία (στοιχεία 2020)	253
1	-	Προαγωγές και αξιολογήσεις στελεχών (στοιχεία έτους 2020)	118
53	11		
Σύνολο Μηνυμάτων	64	Μέγιστο πλήθος επηρεαζόμενων Φυσικών Προσώπων (λειτουργοί της Τράπεζας)	6167
Μηνύματα άνευ προσωπικών δεδομένων			
Έως 14.12.2022	Μετά την 14.12.2022	Περιεχόμενο μηνυμάτων άνευ προσωπικών δεδομένων	Πλήθος φυσικών προσώπων
54	17	Οργανωτικές αλλαγές, Σχέδια Πράξεων, Κανονισμοί Λειτουργίας (2019 έως 2022)	-
8	4	Αιτήματα προς υπάλληλο για παροχή πληροφοριών	-
62	21	Σύνολο Μηνυμάτων 83	-

Η εταιρία κλήθηκε σε ακρόαση ενώπιον του Προέδρου της Αρχής στις 08.02.2024, με το υπ' αριθμ. πρωτ. Γ/ΕΞΕ/451/31-01-2024 έγγραφο της Αρχής. Στην συνεδρίαση παρέστησαν εκ μέρους του υπευθύνου επεξεργασίας οι Μούργελας Ιωάννης, Νομικός Σύμβουλος (ΑΜ ΔΣΑ ...), Σαλακάς Νικόλαος, Νομικός Σύμβουλος (ΑΜ ΔΣΑ ...), Α, υπεύθυνος του τμήματος συμμόρφωσης και Β, Υπεύθυνος Προστασίας Δεδομένων, οι οποίοι

υπεστήριξαν τα εξής:

1. Το περιστατικό έγινε αντιληπτό επειδή τον Σεπτέμβριο του 2022 δημιουργήθηκε η αίσθηση στην διοίκηση της εταιρίας ότι υπήρχε μια διαρροή πληροφοριών όσον αφορά τα μισθολογικά από την διεύθυνση πληροφορικής γιατί φάνηκε κάποιος να είναι ενήμερος για κάποιες αλλαγές, για τις οποίες δεν θα έπρεπε να είναι.
2. Διαπιστώθηκε ότι ο υπάλληλος είχε ανασύρει από το σύστημα Enterprise Vault, χωρίς να έχει εξουσιοδοτημένη πρόσβαση, ένα μήνυμα ηλεκτρονικής αλληλογραφίας με μισθολογικά στοιχεία.
3. Υπήρχε πολιτική ανάκλησης ρόλων της εταιρίας η οποία δεν εφαρμόστηκε.
4. Η έρευνα έδειξε ότι από το 2019 μέχρι το 2022 ο υπάλληλος είχε 24.625 μη εξουσιοδοτημένες προσβάσεις και κατέβασε από το σύστημα Enterprise Vault 64 μηνύματα ηλεκτρονικής αλληλογραφίας. Από αυτά τα 63 αφορούσαν προσωπικά δεδομένα υπαλλήλων της εταιρίας και το ένα περιλάμβανε βιογραφικά υποψηφίων σε σχέση με προκήρυξη θέσεων.
5. Ο υπάλληλος διαβίβασε τα ηλεκτρονικά μηνύματα σε μια ομάδα οκτώ αποδεκτών.
6. Οι εμπλεκόμενοι λειτουργοί απομακρύνθηκαν με λύση σύμβασης εργασίας και υπέγραψαν δήλωση εμπιστευτικότητας.
7. Έχουν παρέλθει από τότε 15 μήνες κατά τους οποίους δεν υπήρξαν ενδείξεις χρήσης των προσωπικών δεδομένων στα οποία οι εμπλεκόμενοι λειτουργοί απέκτησαν μη εξουσιοδοτημένη πρόσβαση.
8. Ο υπάλληλος δεν είχε λόγο χρήσης της δυνατότητας μη εξουσιοδοτημένης πρόσβασης προ του 2019. Στην συνέχεια είχε κίνητρο, εξαιτίας της αλλαγής της διοίκησης της εταιρίας και των συνεπαγόμενων μεταβολών στο προσωπικό.
9. Ελήφθησαν, με αφορμή το περιστατικό, μια σειρά νέων μέτρων ασφαλείας, όπως η δυνατότητα πρόσβασης σε δεδομένα μόνο στις περιπτώσεις που αυτή ζητείται από περισσότερους του ενός εξουσιοδοτημένους χρήστες του συστήματος, ο έλεγχος των προσβάσεων από ανεξάρτητο τμήμα της εταιρίας κλπ. Ως αποτέλεσμα των επιπλέον αυτών τεχνικών μέτρων δεν είναι δυνατή στο εξής η επανάληψη της συγκεκριμένης παραβίασης εξαιτίας οργανωτικού σφάλματος.

Τέλος, η εταιρία υπέβαλε το υπ' αριθμ. πρωτ. Γ/ΕΙΣ/1433/22-02-2024 υπόμνημα, συνοδευόμενο από την πολιτική ασφαλείας ομίλου και την πολιτική διαχειρίσεως

ανθρώπινου δυναμικού, στο οποίο αναφέρονται, μεταξύ άλλων,

1. τα επιπλέον οργανωτικά και τεχνικά που ελήφθησαν μετά το περιστατικό,
2. ότι μετά από ενδελεχή έρευνα σε συνεργασία με εξωτερικό συνεργάτη δεν προέκυψαν ενδείξεις μη εξουσιοδοτημένων προσβάσεων στα συστήματα της εταιρίας μέχρι το Α' τρίμηνο του 2019.

Η Αρχή, αφού έλαβε υπ' όψιν της τα ανωτέρω,

ΣΚΕΦΤΗΚΕ ΣΥΜΦΩΝΑ ΜΕ ΤΟ ΝΟΜΟ

1. Σύμφωνα με την παράγραφο 1 στοιχ. στ' του άρθρου 5 του Κανονισμού (ΕΕ) 2016/679 του Ευρωπαϊκού Κοινοβουλίου και του Συμβουλίου (Γενικός Κανονισμός Προστασίας δεδομένων – εφεξής ΓΚΠΔ), «τα δεδομένα προσωπικού χαρακτήρα υποβάλλονται σε επεξεργασία κατά τρόπο που εγγυάται την ενδεδειγμένη ασφάλεια των δεδομένων προσωπικού χαρακτήρα, μεταξύ άλλων την προστασία τους από μη εξουσιοδοτημένη ή παράνομη επεξεργασία και τυχαία απώλεια, καταστροφή ή φθορά, με τη χρησιμοποίηση κατάλληλων τεχνικών ή οργανωτικών μέτρων («ακεραιότητα και εμπιστευτικότητα»).»

2. Σύμφωνα με το άρθρο 32 του ΓΚΠΔ: «Λαμβάνοντας υπόψη τις τελευταίες εξελίξεις, το κόστος εφαρμογής και τη φύση, το πεδίο εφαρμογής, το πλαίσιο και τους σκοπούς της επεξεργασίας, καθώς και τους κινδύνους διαφορετικής πιθανότητας επέλευσης και σοβαρότητας για τα δικαιώματα και τις ελευθερίες των φυσικών προσώπων, ο υπεύθυνος επεξεργασίας και ο εκτελών την επεξεργασία εφαρμόζουν κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλίζεται το κατάλληλο επίπεδο ασφάλειας έναντι των κινδύνων, περιλαμβανομένων, μεταξύ άλλων, κατά περίπτωση: (..) β) της δυνατότητας διασφάλισης του απορρήτου, της ακεραιότητας, της διαθεσιμότητας και της αξιοπιστίας των συστημάτων και των υπηρεσιών επεξεργασίας σε συνεχή βάση, (..) δ) διαδικασίας για την τακτική δοκιμή, εκτίμηση και αξιολόγηση της αποτελεσματικότητας των τεχνικών και των οργανωτικών μέτρων για τη διασφάλιση της ασφάλειας της επεξεργασίας.

Κατά την εκτίμηση του ενδεδειγμένου επιπέδου ασφάλειας λαμβάνονται ιδίως υπόψη οι

κίνδυνοι που απορρέουν από την επεξεργασία, ιδίως από τυχαία ή παράνομη καταστροφή, απώλεια, αλλοίωση, άνευ αδείας κοινολόγηση ή προσπέλαση δεδομένων προσωπικού χαρακτήρα που διαβιβάστηκαν, αποθηκεύτηκαν ή υποβλήθηκαν κατ' άλλο τρόπο σε επεξεργασία. 3. Ο υπεύθυνος επεξεργασίας και ο εκτελών την επεξεργασία λαμβάνουν μέτρα ώστε να διασφαλίζεται ότι κάθε φυσικό πρόσωπο που ενεργεί υπό την εποπτεία του υπευθύνου επεξεργασίας ή του εκτελούντος την επεξεργασία το οποίο έχει πρόσβαση σε δεδομένα προσωπικού χαρακτήρα τα επεξεργάζεται μόνο κατ' εντολή του υπευθύνου επεξεργασίας, εκτός εάν υποχρεούται προς τούτο από το δίκαιο της Ένωσης ή του κράτους μέλους.»

3. Στην εξεταζόμενη περίπτωση, από τα στοιχεία του φακέλου προκύπτει ότι εξαιτίας της μη εφαρμογής της πολιτικής ασφάλειας της εταιρίας, δεν έλαβε χώρα προσαρμογή του ρόλου του υπαλλήλου στο σύστημα, κατά τη μετακίνηση του σε άλλη οργανική θέση, κατά παράβαση του άρθρου 32 του ΓΚΠΔ. Επιπλέον, εξαιτίας των υψηλών δικαιωμάτων που απαιτούσε η προηγούμενη ιδιότητά του υπαλλήλου (διαχειριστής συστήματος), ο εν λόγω χρήστης διατηρούσε αυξημένη μη εξουσιοδοτημένη δικαιοδοσία σε πόρους του συστήματος για μεγάλο χρονικό διάστημα. Το συγκεκριμένο κενό ασφαλείας οδήγησε σε παραβίαση τύπου ελέγχου πρόσβασης², η οποία παρά την περιορισμένη έκταση της (ένας χρήστης) και το γεγονός ότι εντάσσεται στην κατηγορία των εσωτερικών απειλών (insider threat), θεωρείται κίνδυνος υψηλού ρίσκου που εκθέτει ένα σύστημα σε μεγάλο βαθμό.

Η εν λόγω αστοχία στην προσαρμογή των ρόλων δεν έγινε αντιληπτή για πολύ μεγάλο χρονικό διάστημα (2015-2022) και είχε ως αποτέλεσμα να επηρεαστούν από το περιστατικό 6.167 φυσικά πρόσωπα, οι δε πληροφορίες, στις οποίες αποκτήθηκε μη εξουσιοδοτημένη πρόσβαση, αφορούν και δεδομένα προσωπικού χαρακτήρα ειδικών κατηγοριών (υγείας-ποσοστού αναπηρίας).

4. Από το ανωτέρω κενό ασφαλείας συνάγεται ότι, κατά παράβαση του άρθρου 32 του ΓΚΠΔ, δεν εφαρμόζονταν τα ακόλουθα μέτρα σε επίπεδο αντιμετώπισης εσωτερικών απειλών:

- α. Επαρκής παρακολούθηση συστήματος,
- β. Εφαρμογή πολιτικών ασφαλείας,

² Ο έλεγχος πρόσβασης επιβάλλει πολιτική έτσι ώστε οι χρήστες να μην μπορούν να ενεργούν εκτός των προβλεπόμενων αδειών τους

γ. Επιπρόσθετη παρακολούθηση συστήματος σε επίπεδο δραστηριότητας διαχειριστών,

δ. Ύπαρξη τεχνικών μέτρων τα οποία θα μπορούσαν, εξ ορισμού, να αποτρέπουν τα οργανωτικά σφάλματα αυτής της μορφής, όπως αυτοματοποιημένη μεταβολή σε επίπεδο λογισμικού ή με database triggers³ που προσαρμόζουν τους συστημικούς ρόλους στις τροποποιήσεις πεδίων που αφορούν μεταβολές οργανικών θέσεων.

5. Η εταιρία διαθέτει σύστημα διαχείρισης ειδικών/προνομιακών προσβάσεων (Privilege Access Management – εφεξής PAM). Το λογισμικό που χρησιμοποιεί η εταιρία για να παρακολουθεί τα κανάλια επικοινωνίας και να εντοπίζει αποκλίσεις (Enterprise Vault) εντάχθηκε στο PAM το 2022 και δεν παρακολουθεί την δραστηριότητα των διαχειριστών διεύθυνσης κυβερνοασφάλειας και ασφάλειας πληροφοριών. Εάν η εν λόγω ένταξη είχε λάβει χώρα προγενέστερα και αφορούσε όλους τους χρήστες/διαχειριστές ενδέχεται το κενό ασφαλείας να είχε γίνει αντιληπτό μέσω του συστήματος αυτού και οι συνέπειες του να είχαν μετριαστεί.

6. Από τα παραπάνω δεδομένα προκύπτει παραβίαση της αρχής της εμπιστευτικότητας και, επομένως, στοιχειοθετείται παράβαση του άρθρου 5 παρ. 1 στοιχ. στ' σε συνδυασμό με το άρθρο 32 του ΓΚΠΔ.

7. Με βάση τις προηγούμενες σκέψεις, η Αρχή κρίνει ότι συντρέχει περίπτωση να ασκήσει τις κατά το άρθρο 58 παρ. 2 του ΓΚΠΔ διορθωτικές εξουσίες της σε σχέση με την διαπιστωθείσα παράβαση και ότι πρέπει, με βάση τις περιστάσεις που διαπιστώθηκαν, να επιβληθεί, κατ' εφαρμογή της διάταξης του άρθρου 58 παρ. 2 εδ. θ' του ΓΚΠΔ, αποτελεσματικό, αναλογικό και αποτρεπτικό διοικητικό πρόστιμο κατ' άρθρο 83 του ΓΚΠΔ.

8. Περαιτέρω η Αρχή, έλαβε υπόψη τα κριτήρια επιμέτρησης των προστίμων που ορίζονται στο άρθρο 83 παρ. 2 του ΓΚΠΔ και την παράγραφο 5 στοιχ. β' του ίδιου άρθρου που έχουν εφαρμογή στην παρούσα υπόθεση, τις Κατευθυντήριες γραμμές για την εφαρμογή και τον καθορισμό διοικητικών προστίμων για τους σκοπούς του Κανονισμού 2016/679 που εκδόθηκαν στις 03-10-2017 από την Ομάδα Εργασίας του άρθρου 29 (WP 253) και τις Κατευθυντήριες γραμμές 04/2022 του Ευρωπαϊκού Συμβουλίου Προστασίας Δεδομένων για

³ https://en.wikipedia.org/wiki/Database_trigger

τον υπολογισμό των διοικητικών προστίμων στο πλαίσιο του Γενικού Κανονισμού⁴, καθώς και τα πραγματικά δεδομένα της εξεταζόμενης υπόθεσης και ιδίως τα παρακάτω κριτήρια:

I. Ως επιβαρυντικά στοιχεία:

- α. Ότι ο υπάλληλος είχε δυνατότητα μη εξουσιοδοτημένης πρόσβασης στο σύστημα με αυξημένα δικαιώματα διαχειριστή συστήματος επί μεγάλο χρονικό διάστημα, κατά το οποίο η εν λόγω δυνατότητα δεν έγινε αντιληπτή.
- β. Ότι επηρεάστηκαν ιδιαίτερης σημασίας κατηγορίες προσωπικών δεδομένων, όπως δεδομένα μισθοδοσίας προσωπικού, έκτακτες παροχές (bonus), ηλικία/ημερομηνία γεννήσεως, προϋπηρεσία, εκπαίδευση, κανάλι πρόσληψης, οικογενειακή κατάσταση, στοιχεία εθελουσίας εξόδου προσωπικού, σχόλια διευθυντών και Υποδιευθυντών Διευθύνσεων για την εθελουσία, αξιολογήσεις προσωπικού, μισθοί διευθυντών διευθύνσεων, προαγωγές και αξιολογήσεις στελεχών.
- γ. Ότι επηρεάστηκαν προσωπικά δεδομένα ειδικών κατηγοριών, όπως δεδομένα υγείας-ποσοστό αναπηρίας.

II. Ως ελαφρυντικά στοιχεία:

- α. Κατόπιν του περιστατικού, η εταιρία στο πλαίσιο της πολιτικής συμμόρφωσης προέβη σε μια σειρά ενεργειών ενίσχυσης της ασφάλειας σε τεχνικό και οργανωτικό επίπεδο, ούτως ώστε να ενισχυθεί η ασφάλεια του συστήματος με τη λήψη τεχνικών μέτρων και να περιοριστεί η δυνατότητα να επαναληφθεί το ίδιο περιστατικό.
- β. Κατόπιν του περιστατικού, επιβλήθηκαν μέτρα κατά των υπαλλήλων της εταιρίας που ενεπλάκησαν στην διαρροή προσωπικών δεδομένων.
- γ. Κατόπιν του περιστατικού, πραγματοποιήθηκε έρευνα σε πλήρη συνεργασία με τη Διεύθυνση Εσωτερικού Ελέγχου της Τράπεζας με τη χρήση ειδικού

⁴ https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under_en - έκδοση 2.0, μετά τη διαβούλευση.

λογισμικού από την εταιρία Alvarez & Marsal, η οποία απέστειλε στην Ελλάδα, από τη Μ. Βρετανία, εξειδικευμένο προσωπικό.

δ. Η διαρροή προσωπικών δεδομένων ως συνέπεια του περιστατικού ήταν μικρής έκτασης και οι συνέπειες από το περιστατικό ήταν περιορισμένες αναλογικά με το μέγεθος της εταιρίας.

III. Τον τελευταίο ενοποιημένο διαθέσιμο κύκλο εργασιών της εταιρίας (01/01/2022-30/06/2022) που ανέρχεται σε **2.194.008.000€**.

9. Κατόπιν συνεκτίμησης των ανωτέρω επιβαρυντικών και ελαφρυντικών κριτηρίων (σκέψη 8 σημεία i) και ii) ανωτέρω), καθώς και τον κύκλο εργασιών του ΥΕ (σκέψη 8 σημείο iii) ανωτέρω), η βαρύτητα των διαπιστωμένων παραβάσεων κρίνεται ως μικρή. Ως εκ τούτου, η Αρχή κρίνει ότι πρέπει να επιβληθεί στην εταιρία με την επωνυμία «ALPHA BANK ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ» πρόστιμο κοντά στα χαμηλά του στατικού εύρους που ορίζουν οι κατευθυντήριες γραμμές 4/2022 του ΕΣΠΔ για το είδος των παραβάσεων με μικρή σοβαρότητα και ίσο με το 3.000€.

ΓΙΑ ΤΟΥΣ ΛΟΓΟΥΣ ΑΥΤΟΥΣ

Η Αρχή

Ασκώντας τις διορθωτικές εξουσίες με βάση το άρθρο 58 παρ. 2 στοιχ. θ) του ΓΚΠΔ, επιβάλλει πρόστιμο ύψους τριών χιλιάδων ευρώ (3.000€) στην εταιρία με την επωνυμία «ALPHA BANK ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ», για τους λόγους που εκτενώς αναφέρονται στο σκεπτικό.

Ο Πρόεδρος

Η Γραμματέας

Κωνσταντίνος Μενουδάκος

Ειρήνη Παπαγεωργοπούλου